

Firewall de IoT

Según una encuesta realizada por la firma [de](#) seguridad Extreme Networks, casi el [70% de las organizaciones sufrieron ataques contra sus dispositivos IoT](#). Y muchos de esos ataques resultaron en una violación. Ese número asombroso deja claro por qué la seguridad de la red IoT es un aspecto tan esencial para mantener una postura de seguridad general fuerte.

Los firewalls, que restringen el tráfico de red entrante y saliente en función de las reglas definidas por el usuario, son elementos básicos de la seguridad de la red, y [los dispositivos IoT](#) no son una excepción. De hecho, el firewall es particularmente importante para IoT. Con un firewall de IoT, los administradores pueden limitar su superficie de ataque y reducir el riesgo de un ataque que conduce a una violación.

Por ejemplo, una cámara inalámbrica no debería aceptar escaneos para puertos SSH abiertos de todo el mundo. Un firewall de IoT puede restringir el acceso para evitar esos escaneos y reducir las posibilidades de que un atacante descubra un dispositivo.

Este artículo explorará qué es un firewall de IoT, cómo funciona y proporcionará un ejemplo práctico paso a paso de la configuración del firewall de IoT.

Resumen: tradicional vs. Firewalls de IoT

Los dispositivos IoT difieren de los dispositivos de firewall de red tradicionales. Antes de saltar a los detalles, comencemos con una visión general de alto nivel de los tradicionales vs. Firewalls de IoT.

Firewall tradicional

Firewall de IoT

	Firewall tradicional	Firewall de IoT
Configuración	Org-wide configurado manualmente por el administrador del sistema.	La configuración es solo una parte de la configuración de Infraestructura como Código (IaC).
Dispositivos protegidos	El administrador puede aplicar cambios a todas las máquinas utilizando privilegios de administrador de dominio y ajustar la configuración de seguridad.	Los dispositivos pueden ser difíciles de administrar de manera uniforme, amplificando la importancia de cubrirlos a todos detrás de un firewall.
Diversidad de tráfico	Debido a que el tráfico es diverso, las reglas del firewall son laxas para evitar romper la funcionalidad.	El tráfico es predecible y de alcance limitado. Por lo tanto, las reglas de firewall pueden ser más estrictas.

Comprensión de los firewalls de IoT

Los firewalls de IoT se ocupan de dispositivos cuyos patrones de tráfico son significativamente diferentes a los dispositivos en una arquitectura tradicional de cliente / servidor. Con los modelos de arquitectura cliente/servidor, los clientes envían un conjunto diverso de servidores y reciben respuestas, generalmente utilizando un subconjunto de puertos comunes como 80 (HTTP) y 443 (HTTPS).

Diagrama simplificado que muestra cómo un firewall encaja en una red IoT. ([Fuente](#)).

Este patrón de tráfico proporciona una base para la creación de reglas de firewall. Por ejemplo, sabemos que las solicitudes entrantes no solicitadas a un cliente no tienen lugar en esta arquitectura. También sabemos que es poco probable que cierta actividad de red se origine de un usuario legítimo, como los escaneos de red.

Sin embargo, el tráfico general de la red es lo suficientemente diverso como para crear reglas de firewall efectivas que equilibren la seguridad y la

usabilidad puede ser un desafío.

IoT es diferente. La mayoría de los dispositivos IoT realizan un conjunto predefinido de solicitudes a destinos específicos y solo deben recibir conexiones entrantes desde algunas ubicaciones de red conocidas. Por lo tanto, los cortafuegos pueden asumir una postura más asertiva en la regulación de este tráfico. Por ejemplo, un firewall de IoT puede no permitir el tráfico no HTTPS a un refrigerador inteligente porque otro tráfico no debería ocurrir en un dispositivo de este tipo.

Comparar

Plataforma	Procesamiento de eventos en tiempo real	Rendimiento de la escala de Internet	Procesamiento de dispositivos de borde estatual	Replicación entre regiones	Geo-Fencing y Data-Pinning
Borde de Azure IoT	✓	✓			
AWS IoT Greengrass	✓	✓	✓		
Macrometa	✓	✓	✓	✓	✓

Implementación de un firewall IoT

Sin embargo, la mayoría de las organizaciones modernas se beneficiarán del uso de la infraestructura como código (IaC) para la configuración de firewall de IoT. Esta sección lo guiará a través de la implementación de un firewall de aplicaciones web IoT (WAF) basado en la nube para una flota de dispositivos geográficamente dispersa.

Mapeo de la infraestructura

Un firewall, en cierto sentido, refleja la funcionalidad prevista de la red. Por lo

tanto, un buen WAF debe reflejar el flujo de red previsto de su aplicación.

Imagine una red de dispositivos [ESP32](#) que miden la actividad volcánica en puntos de acceso en todo el mundo. Los dispositivos se conectan a una [puerta de enlace WiFi G1](#) de alta potencia, que se conecta al router de una estación de monitoreo de geología cercana. Los geólogos confían en este router para sus dispositivos personales y profesionales. El router se conecta a un módem y que se conecta a Internet. Por lo tanto, los dispositivos IoT se conectan a través de Internet al backend de la API para el registro, comandos, etc.

Modelo simple de cómo fluye el tráfico a través de nuestra infraestructura de IoT

En la API de backend a la que se conectan los dispositivos de medición volcánica, los desarrolladores incluyen un simple punto final de eco al que los dispositivos pueden llamar para garantizar que la API responda. Vamos a utilizar un WAF para proteger este punto final.

```
import { Application } from "https://deno.land/x/oak/mod.ts";
import { h, renderSSR } from "https://deno.land/x/nano_jsx@v0.0.20/mod.ts";

const app = new Application();

function App({echo}) {
  return (
    echo: {echo}
  );
}

app.use((ctx: any) => {
  ctx.response.headers.set("Content-Type", "text/html")
  const { searchParams: query } = new URL(ctx.request.url);
  ctx.response.body = renderSSR();
});

await app.listen({ port: 8000 });
```

Hay mucho que podríamos hacer para mejorar el código anterior, pero ignorarlo por ahora. Solo queremos centrarnos en cómo un firewall podría

contribuir a la seguridad del código anterior.

Implementación de nuestro firewall de aplicaciones web

Como desarrolladores, debemos luchar por una excelente seguridad. Por ejemplo, el punto final de eco anterior es vulnerable a un ataque [de secuencias de comandos de sitios cruzados](#) (XSS) [reflejado](#). Un atacante puede ejecutar código arbitrario en un navegador que visita ese punto final proporcionando un parámetro de eco que contiene código HTML con una carga útil JS.

El ataque XSS reflejado contra el código de punto final de eco.

Vamos a implementar un WAF para evitar cualquier XSS contra este punto final añadiendo el siguiente código a nuestra aplicación:

```
import waf from 'https://deno.land/x/waf/waf.tsx';

//Forbid HTML in the echo parameter
app.use(waf({
  parameters: [{
    name: 'echo',
    disallowTags: true
  }]
}));
```

Además, queremos que nuestro código se ejecute en un entorno de nube real. Para el ejemplo a continuación, utilizamos [Deno Deploy](#), pero debido a que el firewall está a nivel de aplicación, debería funcionar sin problemas con cualquier proveedor de nube.

Probemos el mismo exploit XSS que antes contra nuestra aplicación protegida por WAF y desplegada en la nube.

El módulo WAF de Deno bloquea el HTML no deseado en el parámetro especificado

Wonderful: nuestro firewall impidió que el parámetro de eco dañado explotara nuestro código de aplicación vulnerable. Así es exactamente como deben

funcionar los firewalls: hacerte más seguro al proporcionar una capa adicional de protección entre tu infraestructura y los atacantes.

Mejores prácticas de firewall IoT

Hemos analizado qué es un firewall de IoT y cómo usarlo. Ahora revisemos algunas de las mejores prácticas que le ayudarán a mantener su firewall seguro y fácil de mantener.

Documentar todas las reglas del firewall

Imagine que un ingeniero está tratando de implementar una nueva función de API que se conecta a un determinado recurso, pero el firewall está bloqueando la conexión.

Por lo tanto, compruebe una lista negra de IP prohibidas dentro de la configuración de su firewall y vea que el destino aparece allí.

```
$ firewall -ipv4 -list blacklist
103.251.167.20
61.177.173.51
164.92.218.139
171.251.29.152
185.246.188.95
45.153.160.131
185.129.63.2
61.177.173.35
61.177.173.39
89.234.157.254
23.129.64.130
```

Podría obtener la IP del dominio y confirmar que está en la lista, pero ¿realmente desea eliminar una IP de la lista negra? Después de todo, probablemente fue puesto allí por una razón.

Es por eso que es crucial documentar sus decisiones al agregar una regla al

firewall. Supongamos que agrega la dirección IP utilizada por una botnet IoT conocida a una lista negra, y el dispositivo de alguien se infecta y deja de funcionar porque el malware en su dispositivo no puede llamar a casa correctamente. Otro administrador de TI podría asumir que la lista negra es el problema y eliminar la regla.

Ya sea simplemente usar iptables -c para agregar un comentario en el archivo de configuración del firewall o mantener una hoja de cálculo completa que explique diferentes reglas, tenga algo en su lugar que otros administradores puedan consultar cuando necesiten modificar su trabajo.

Utilice la herramienta adecuada para su infraestructura.

Los clientes de AWS, por ejemplo, encontrarán fácil integrar [AWS Network Firewall](#) con otros servicios de AWS como Lambda, EC2, etc.

No te preocupes por encontrar la solución "perfecta". En su lugar, busque una integración sólida con el resto de su infraestructura. Encuentre la solución de firewall "típica" para su pila de tecnología específica y vea si satisface sus necesidades.

Restringir todo excepto el tráfico necesario

Los cortafuegos deben seguir el [principio de privilegio mínimo](#). Para los firewalls de IoT, eso significa bloquear agresivamente cualquier entrada o salida de tráfico que no coincida con los patrones esperados.

¿Cómo se ve esto en la práctica? Imagine que tiene un dispositivo que ocasionalmente envía estadísticas a una API de monitoreo, pero nunca recibe tráfico entrante. Debe configurar su firewall para:

- Permitir que el dispositivo envíe solicitudes de monitoreo solo en el puerto correcto y al destino correcto.
- Bloquee todos los demás destinos salientes.
- Bloquee completamente el tráfico entrante.

Escanee su red en busca de dispositivos "olvidados"

Los dispositivos IoT como las cámaras de circuito cerrado de televisión, los quioscos minoristas y los teléfonos inteligentes a menudo son nodos "olvidados" en una red. Estos dispositivos son propensos a descuidar porque es posible que ni siquiera aparezcan en las listas de inventario.

Cazar dispositivos deshonestos suena intimidante, pero comienza con un simple comando de Linux. Entonces, te aseguras de que todos los resultados tengan sentido. Aquí hay un ejemplo de un análisis completo de la red de área local utilizando un mapa en una red con IoT y dispositivos convencionales.

```
$ nmap -sP 192.168.0.0/24
Starting Nmap 4.00 ( http://www.insecure.org/nmap/ ) at 2010-06-22 22:27
Host ROUTER 192.168.0.0 appears to be up.
Host MODEM appears to be up.
Host DAVE'S IPHONE (192.168.0.2) appears to be up.
Host HDV Smart Fridge (192.168.0.9) appears to be up.
Host Allen@org.example (192.168.0.10) appears to be up.
Host jfrey@org.example (192.168.0.11) appears to be up.
Host Thermostat (192.168.0.16) appears to be up.
Host 192.168.0.17 appears to be up.
Host 192.168.0.18 appears to be up.
Host testapi.org.example.dev (192.168.0.19) appears to be up.
[...]
Nmap finished: 256 IP addresses (211 hosts up) scanned in 7.491 seconds.
```

Rastrear e inventariar esos dispositivos puede ser tedioso. Sin embargo, vale la pena el esfuerzo de obtener visibilidad de los dispositivos a través de su red y eliminar superficies de ataque innecesarias.

Almacene, sirva y procese datos en cualquier parte del mundo

Mejore el rendimiento de escritura con una arquitectura activa-activa distribuida globalmente

Escalar con una capa de datos en tiempo real, accesible dentro de la proximidad de 10ms del 80% de la población mundial.

Admite múltiples tipos de datos (KV, Docs, Gráficos y Búsqueda) y datos de transmisión

[Descargar Libro Blanco Gratis](#)

Conclusión

Ya sea que simplemente configure iptables en un sistema Linux heredado o proteja el backend web de su aplicación IoT con un AWS WAF, los firewalls proporcionan un beneficio de seguridad de red significativo con una inversión inicial relativamente pequeña en tiempo y dinero.

Con la información que hemos revisado aquí, usted tiene una línea de base para decidir qué solución de firewall de IoT es apropiada para su infraestructura y cómo ejecutarla. Siguiendo el principio de privilegio mínimo con sus reglas de firewall y tomándose el tiempo para descubrir todos los dispositivos IoT en su red, puede mejorar drásticamente su postura de seguridad general.

[Obtenga más información](#) sobre cómo Macrometa se integra con su entorno IoT sin problemas y le brinda un acceso sin esfuerzo, escalable y confiable a sus datos desde una variedad de marcos populares.

Este contenido fue producido por Inbound Square

